

Real-time questions during class – Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Go to <https://claper.fi.muni.cz/e/pv210> or <https://claper.fi.muni.cz> and type event code **pv210**.



MUNI

Incident Handling

Week 2

PV210 Cybersecurity Team and Its Services

September 23, 2026

Martin Laštovička

Agenda

- Cyber Threat Landscape
- Incident Handling Phases
- Incident Handling Phases – Exercise
- Incident Triage

M U N I

Cyber Threat Landscape

ENISA – European Union Agency for Cybersecurity

- Original name „*European Network and Information Security Agency*“
- Established in 2004, strengthened by the [EU Cybersecurity Act](#) in 2019
- More mandate from new Acts, e.g., [Cyber Resilience Act](#) in 2024
- Main mission
 - Contributes to EU cyber policy
 - Enhances the trustworthiness of ICT products, services and processes with cybersecurity certification schemes
 - Cooperates with Member States and EU bodies
 - Helps Europe prepare for the cyber challenges of tomorrow
- Works to strengthen trust in the connected economy, to boost resilience of the EU infrastructure, and to keep society and citizens digitally secure

ENISA Cyber Threat Landscape Report

- Annual report on the state of cybersecurity within the EU
- Based on the analysis of real incidents and vulnerabilities from open sources and ENISA's own Cyber Threat Intelligence (CTI) capabilities
- Identifies
 - prime threats
 - major trends observed with respect to threats
 - threat actors
 - attack techniques

ENISA Cyber Threat Landscape Report

- Describes relevant mitigation measures and recommendations
- Combines strategic and technical elements, catering to both technical and non-technical audiences
- Serves for decisions and prioritisation of actions for management

Other Threat Landscapes and Sources

- Most of the global cybersecurity vendors produce their own reports
 - E.g., [Fortinet](#), [CrowdStrike](#), [CyberArk](#), [Elastic](#)...
- UN ICC – United Nations International Computing Centre
 - [Threat landscape 2024](#) released in April 2025 (report for 2025 or 2026 not yet...)
 - <https://www.unicc.org/our-impact/resources>
- CISA – U.S. Cybersecurity and Infrastructure Security Agency
 - [Known Exploited Vulnerabilities Catalog](#)
 - CISA's authoritative source of vulnerabilities that have been exploited in the wild
 - Organizations should use the KEV catalog as an input to their vulnerability management prioritization framework

ENISA Threat Landscape 2025

- See [full report](#)
- Released in October 2025, updated January 2026
- Huge changes in the last 2 years
- We can expect 2026 report in the next months

ENISA Threat Landscape 2025 KVIS

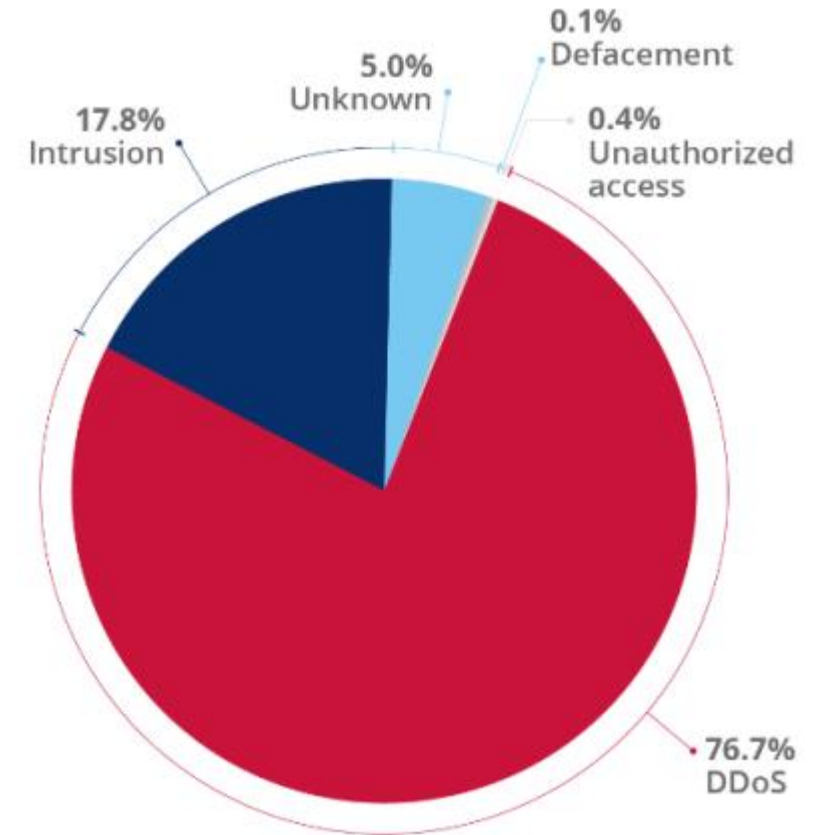
ENISA Threat Landscape 2025 Answers

- Do not cheat the KVIS by looking at answers on the following slides

What is the Overall Most Prominent Threat?

Figure 2: Distribution of incident types

1. DDoS 76,7 %
 - big increase in last 2 years
2. Intrusions 17,8 %
3. Unknown 5 %
4. Unauthorized access 0,4 %
5. Defacement 0,1 %



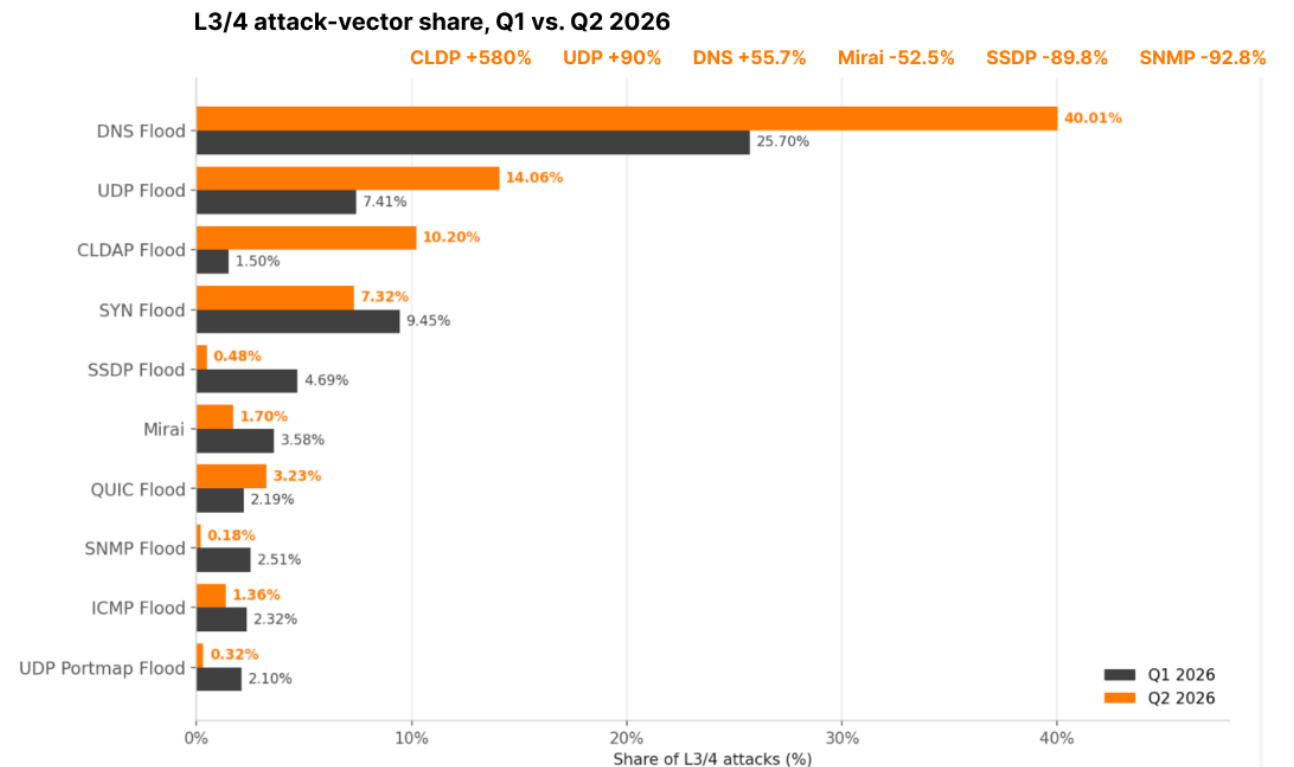
What is the Most Common DDoS Attack Vector?

– ENISA uses Cloudflare and Akamai reports

– <https://blog.cloudflare.com/ddos-threat-report-2026-h1/>

– Big changes every year / quarter

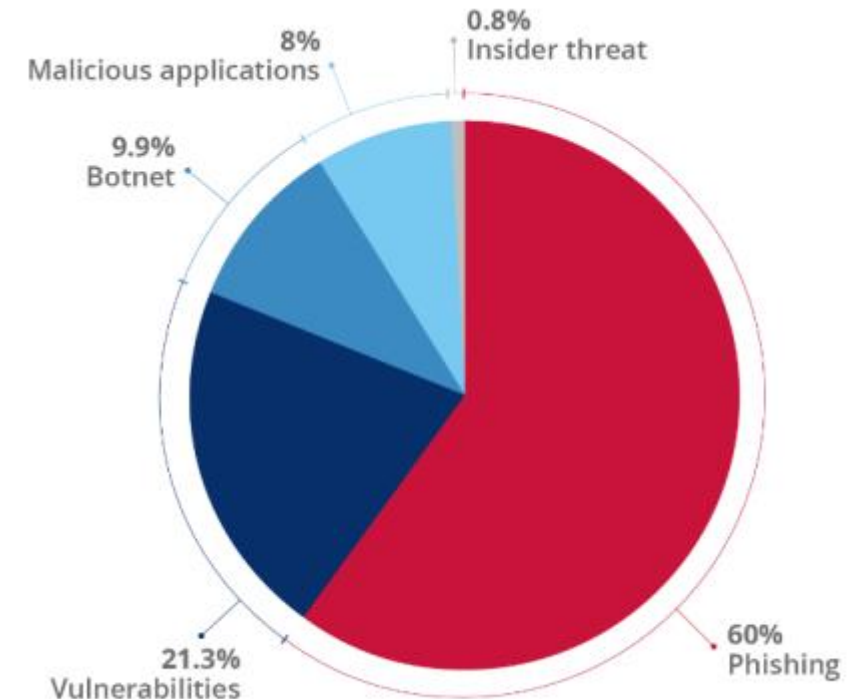
1. DNS flood 40 %
2. UDP flood 14 %
3. CLDAP flood 10,2 %
4. TCP SYN flood 7,3 %



What is the Top Attack Vector For Intrusions?

Figure 1: Most identified initial attack vector

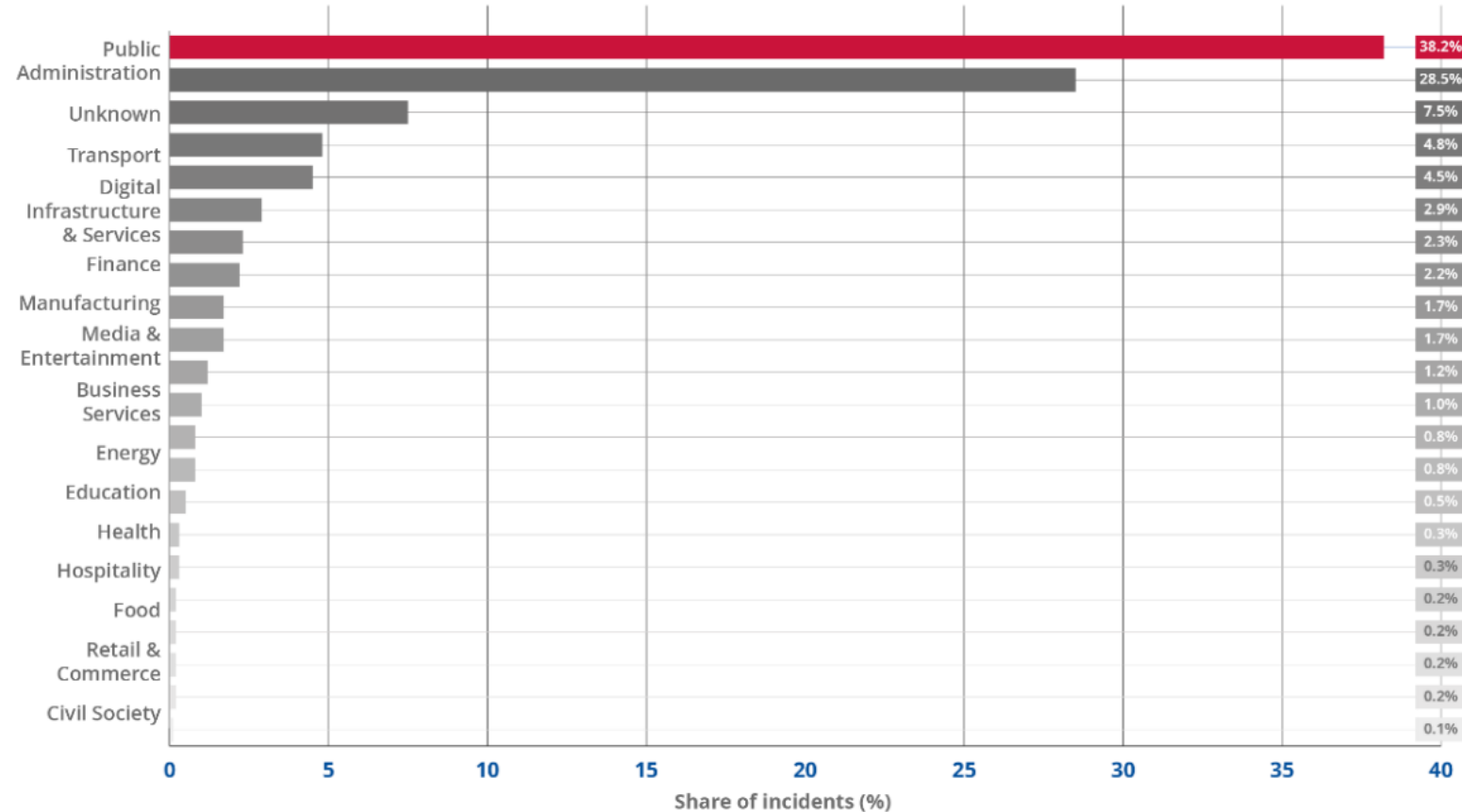
1. Phishing 60 %
2. Vulnerabilities 21,3 %
3. Botnet 9,9 %
4. Malicious applications 8 %
5. Insider 0,8 %



What is the Most Common Target?

Figure 7 Share of recorded incidents by sector

1. Public admin 38,2 %
 2. Unknown 28,5 %
 3. Transport 7.5 %
 4. Digital infrastructure and services 4.8 %
- Education 1,7 %



What Is the Most Commonly Discovered Weakness (CWE) in Published Vulnerabilities?

Figure 45: Top 25 commonly seen CWEs.

1. XSS 56,92 points
2. OoB Write 45,2 points
3. SQLi 35,8 points
4. CSRF 19,57 points

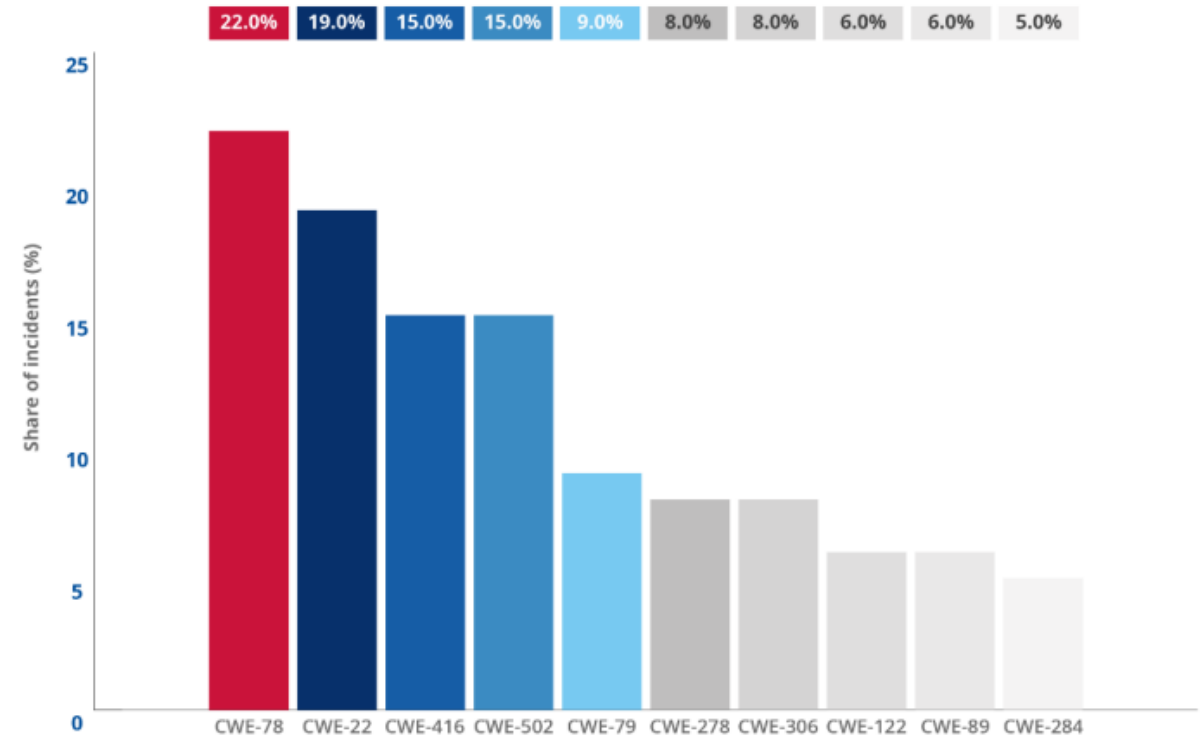
Rank	ID	Name	Score	CVEs in KEV	Rank Change vs. 2023
1	CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	56,92	3	+1
2	CWE-787	Out-of-bounds Write	45,2	18	-1
3	CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	35,88	4	0
4	CWE-352	Cross-Site Request Forgery (CSRF)	19,57	0	+5
5	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	12,74	4	+3
6	CWE-125	Out-of-bounds Read	11,42	3	+1
7	CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	11,3	5	-2
8	CWE-416	Use After Free	10,19	5	-4
9	CWE-862	Missing Authorization	10,11	0	+2
10	CWE-434	Unrestricted Upload of File with Dangerous Type	10,03	0	0

— What is a „score“ ENISA doesn't say

What Is the Most Commonly Discovered Weakness (CWE) in Exploited Vulnerabilities?

Figure 48: Top 10 weaknesses leading to vulnerabilities added to the CISA KEV

1. OS Command Injection 22 %
2. Path Traversal 19 %
3. Use After Free 15 %
4. Deserialization of Untrusted Data 15 %
5. XSS 9%

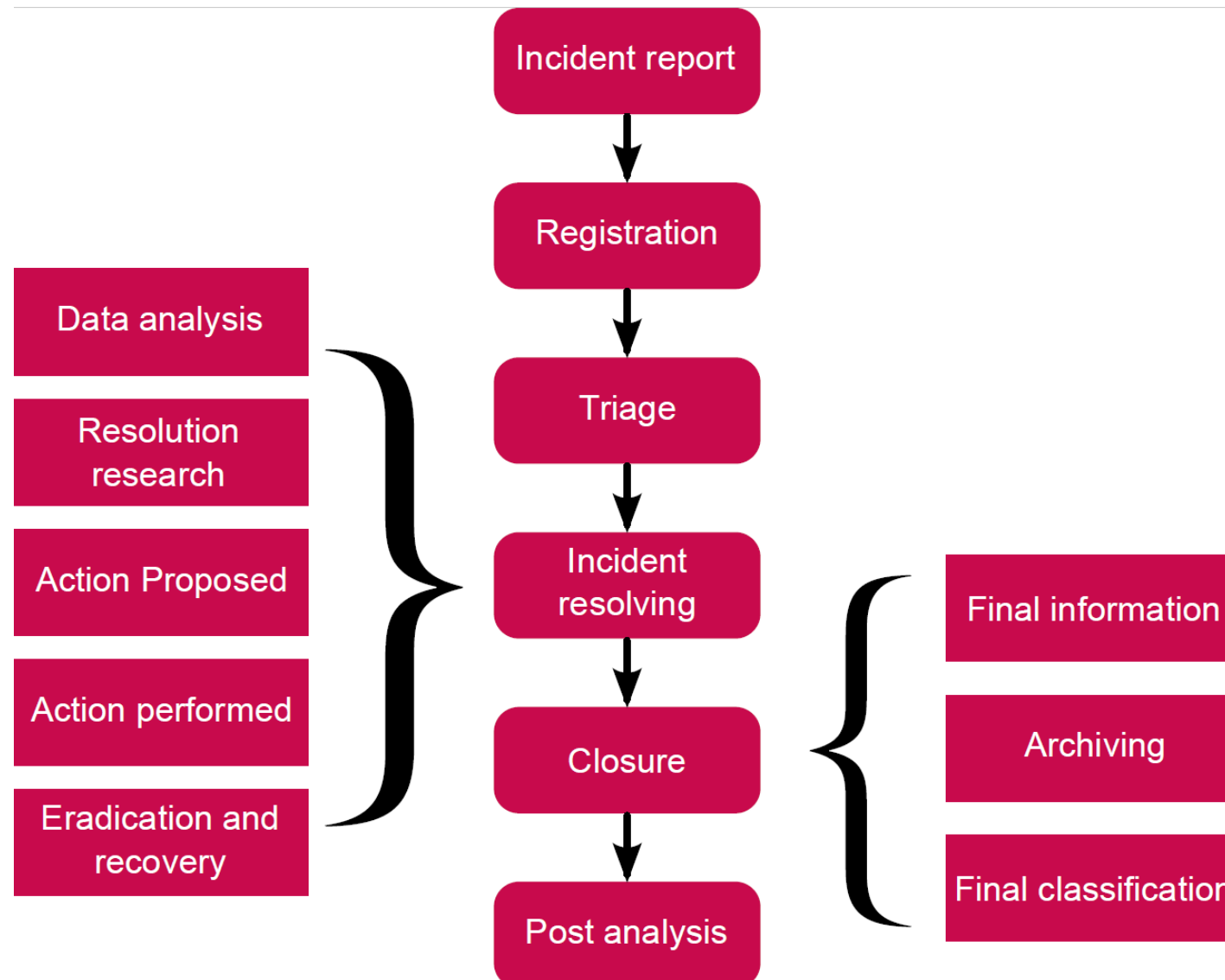


Key Trends Seen by ENISA

- Phishing remains a primary initial intrusion vector
 - With a raise in ClickFix-style phishing
- Increasingly targeted cyber dependencies and supply-chain
- Continuous targeting of mobile devices
- Threat groups converging
 - The lines between hacktivism, cybercrime and state-nexus activity continued to blur
- Use of AI

M U N I

Incident Handling Phases



Incident Report

- Various communication channels
 - Web form, E-mail, Phone, Verbal report, Message from IDS, CSIRT own activity
- Reports may come from within and outside of the organization
- CSIRT must define how to report incident
 - Contact points (e-mail address, phone number), usage of digital signatures/encryption
 - Examples:

<https://it.muni.cz/en/services/security-incidents-reporting>

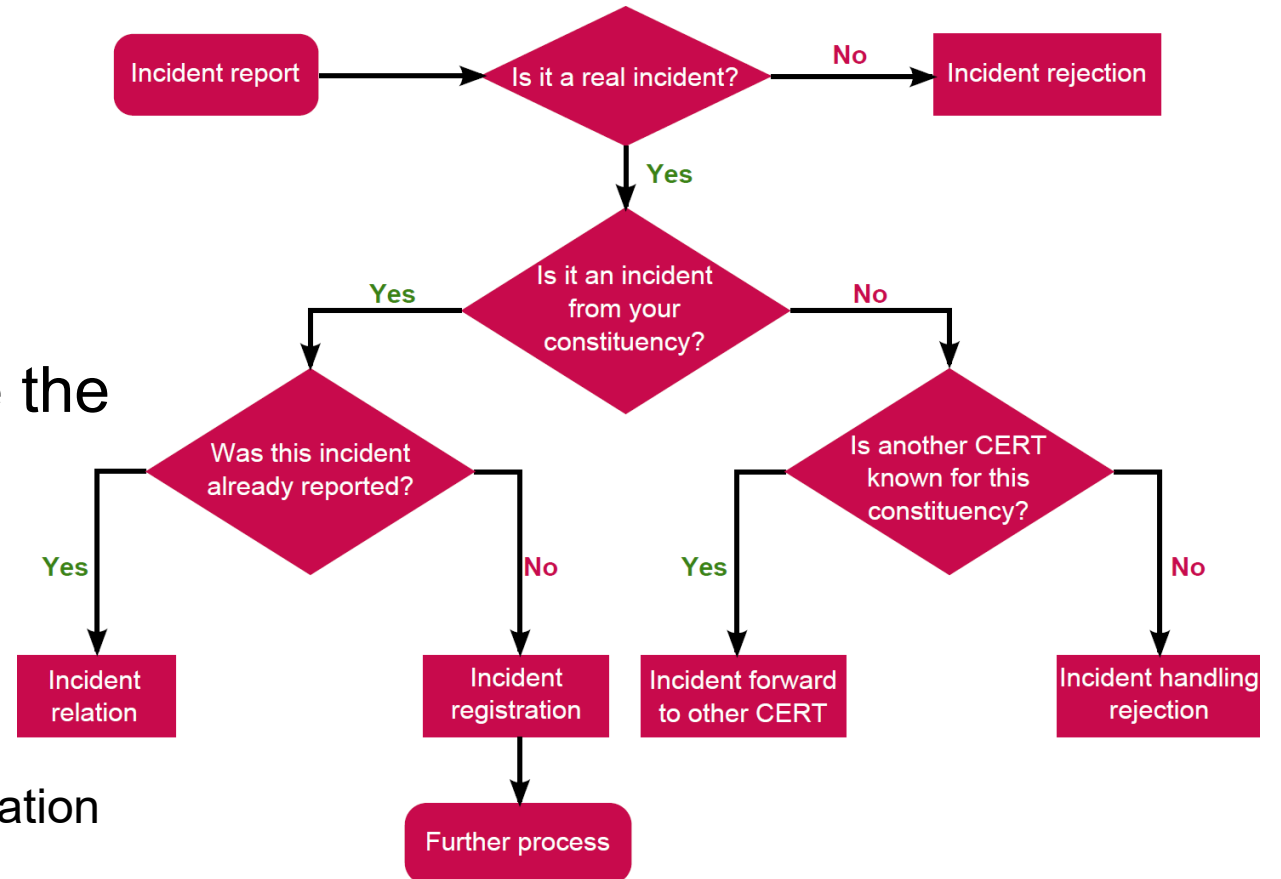
<https://nukib.cz/en/cyber-security/government-cert/incident-reporting/>

Registration

- Report inserted into incident handling system
 - Usually automatic for e-mails, forms, etc.
- Spam filters
 - Saves time managing the system
 - Reports from automatic reporting services often falls into spam
- Assign incident ID
- Assigning person who proceeds with the incident triage

Triage

- Initial assessment of the report
- Incident verification
- Check if you have mandate to solve the incident
 - Does it fall inside your constituency?
- Check for duplicates
 - Remove duplicate reports
 - Update already opened case with new information
- Accept report for further process



[ENISA Good Practice Guide for Incident Management](#), p. 38

Triage Further Steps

- Incident classification
 - i.e., [ENISA Reference Security Incident Classification Taxonomy](#)
- Incident prioritization
 - Based on incident classification
 - Based on targeted system/customer
- Incident assignment
 - Allocate the required number of incident handlers and assign them for the task
 - Typically the one who picked up the incident from the system

Incident Resolving – Data Analysis

- Collect data that most likely contain the information you need
 - Monitoring systems, relevant log files
 - System setup and configuration
- An incident can result in a real legal case
 - Proper collection needed
- Data from third parties
 - They don't see why they should provide data for incident of someone else
 - E.g., another department, ISP
- Analyze the data

Incident Resolving – Resolution Research

- Collect ideas drawn during data analysis
 - Brainstorming if more analysts were involved
- The solution is usually very simple
- Timeliness of reaction
 - Analysts tend to desire to „know everything“ and do long thorough analysis
 - Sometimes a quick response on incomplete data has higher value (basic incidents)
 - On critical infrastructure, you need to be sure

Incident Resolving – Action Proposed

- Set of concrete and practical tasks for each party
- The tasks must be understandable
 - Language of the party
 - Technical knowledge (instructing sysadmin vs. accountant with infected notebook)
- You must be prepared to take responsibility for the actions

Incident Resolving – Action Performed

- Were all actions really carried out?
 - You have no control over other parties
- Monitor the progress
 - Is the service turned off?
 - Is the system patched?
 - Can you still see the malicious traffic?
- Request the action again if it takes too long
 - You should have internal policy on the response time

Incident Resolving – Eradication & Recovery

- The incident was stopped and threat removed
- Ensure all systems went back online
- Get confirmation from each party that their operations are back to normal

Closure

– Final information

- Description of the incident
- Results of your work
- Main findings and recommendations

– Final classification

- Important for statistics and high-level decisions about security
- Additional work for the handlers – need to keep it simple

– Archiving

- Contains personal and sensitive data, must be encrypted
- Data must be destroyed after a legal period of archiving

Post Analysis

- Not every incident is worth analyzing
 - Focus on incidents with new attack vectors, complex analysis, difficult cooperation, etc.
- Lessons learned
- Proposal for improvement
 - Prepare tools/manuals for data collection
 - Prepare manual how to better report an incident and include relevant information
 - Propose a new policy / security policy

MUNI

Incident Handling Phases – Exercise

PV210 Cybersecurity in an Organization

Goal of this exercise

- Recognize handling phases of a real incident
- Work in a pair

Let's start!

- Make a pair
- Order the actions done by the response team according to the incident handling phases.
- Time limit: 3 minutes
- If the text on the slides is too small, you can read it [in PDF in IS](#).

Actions A

- Verification whether the report is relevant to the team and contains information the team can confirm.
- Checking records from network monitoring for the reported communication.
- Classifying the incident as “Availability - Distributed Denial of Service”.
- Determining the priority as low because user devices in Eduroam is not a critical asset.
- Assigning the incident to one handler.

Actions B

- The handler wrote a short summary of the incident for internal use (other CSIRT members, reporting to the management) and saved it to the ticket system:
- Four user devices were abused to DDoS attack using a proxyware application installed by the students. The incident was resolved by uninstalling proxyware from all affected devices.
- The incident was eventually classified as “Intrusions – System Compromise” in the ticket system and closed.

Actions C

- Since the incident was a new type of DDoS where users “infected” their devices willingly, the team published a warning for all users explicitly stating such applications violate university directive.
- New detection method was written to discover all users with proxyware applications.

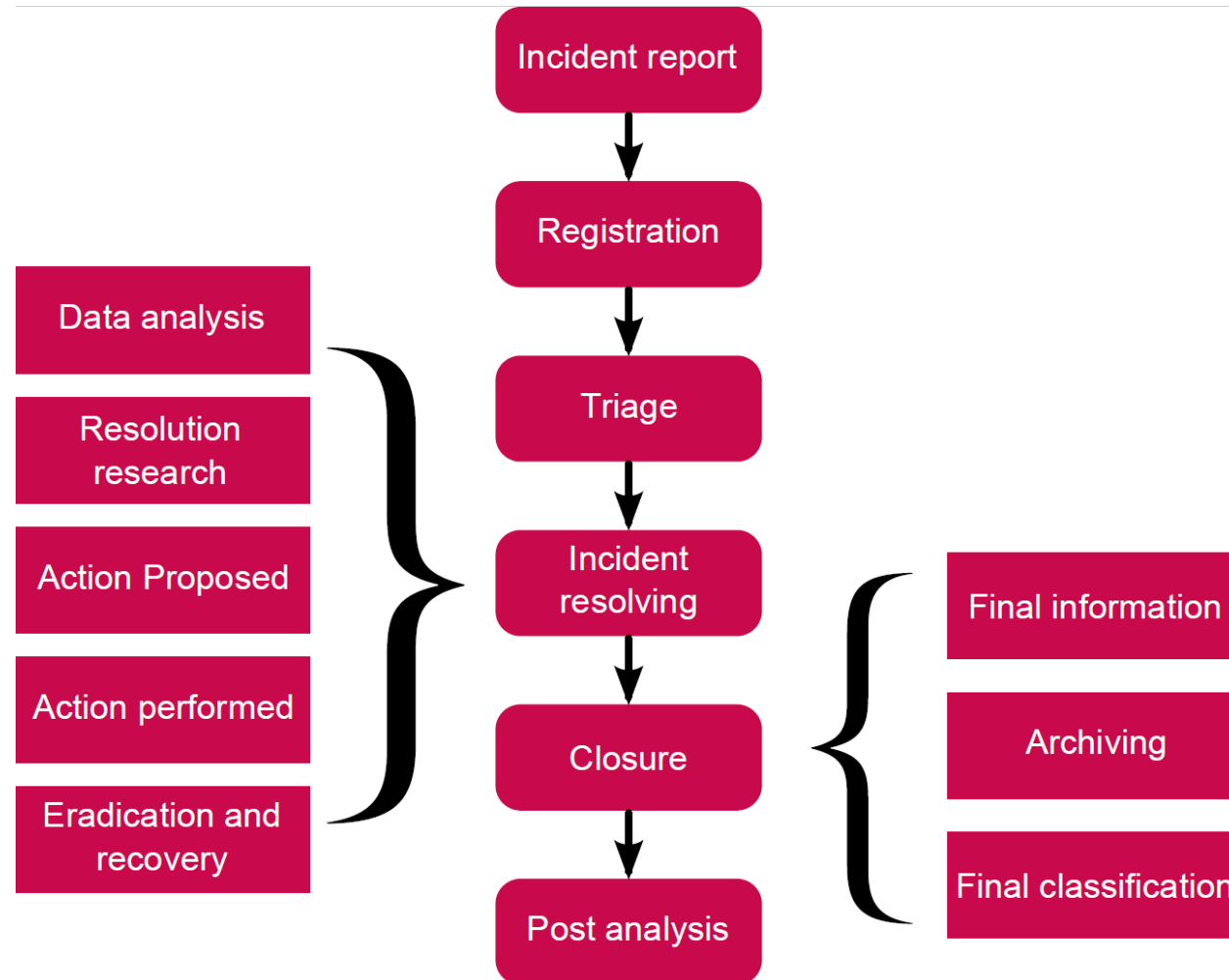
Actions D

- Four machines were abused for the DDOS attack through a proxyware application. The solution is removing the application from the device and checking the device with an anti-virus for other possible infections.
- These actions were proposed to the end users.
- Users removed the application and checked their devices.

Actions E

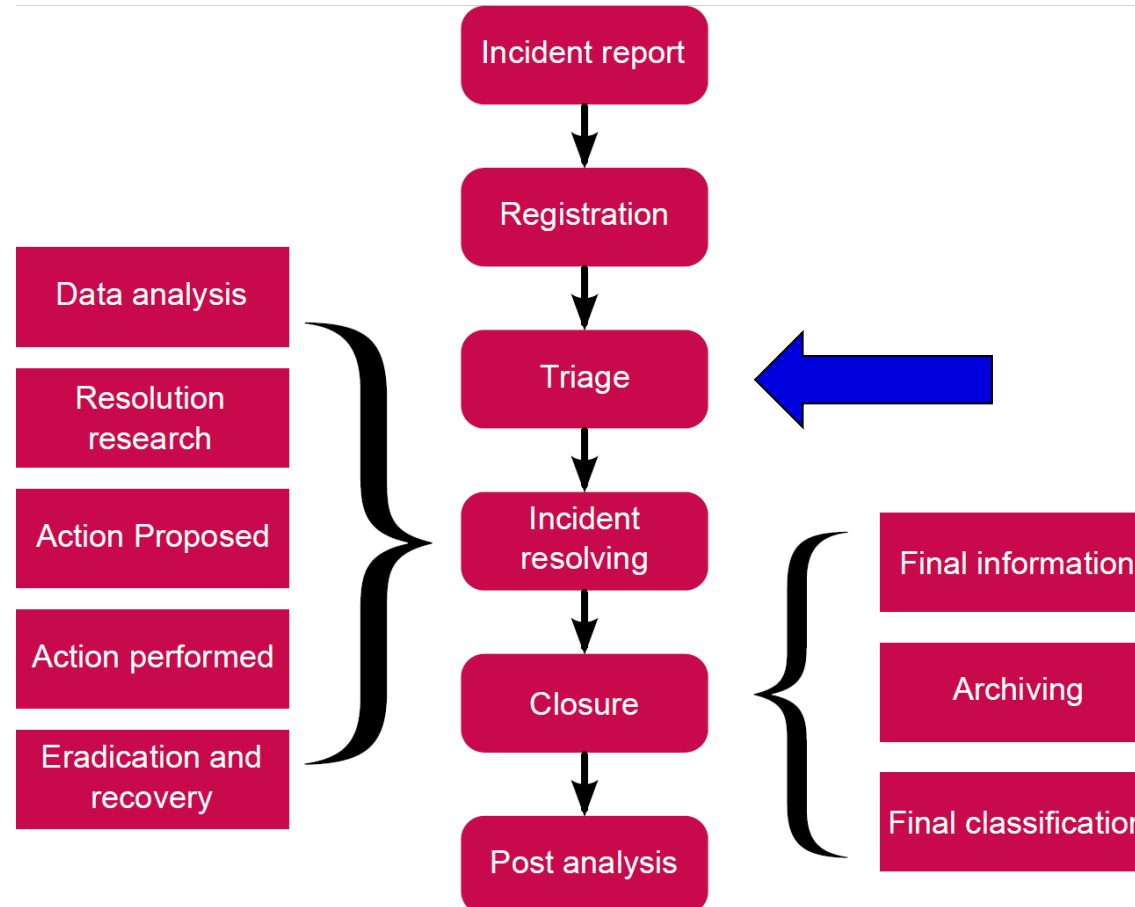
- Reading the following report
 - Dobrý den,
obracím se na Vás s žádostí o pomoc v situaci, kdy na jeden zákaznický web byl dnes veden DDOS útok.
Do této konverzace jsem Vás přidal z důvodu, že útok šel i z Vaší sítě. Zároveň se omlouvám všem sítím, které měly jen v logu jen jednu adresu, ale naopak tam čekám, že budou akčnější a třeba poskytnou nějaký zajímavý hint.
 - Parametry útoku:
 - L7 HTTPs flood
 - URL
adresa: <https://www.kniha<redacted>.cz/shop/default?do=setfavourite&oid=335800&page=495>
- Začátek: 13.02.2026 15:18
- Konec: 13.02.2026 15:35
 - Zajímavé na tomto útoku je převážně fakt, že do něj bylo zapojené velké množství českých IP adres. Domnívám se tedy, že zde existuje botnet, za kterým stojí naši spoluobčané. Nejspíš k tomu využívají nějakou aplikaci/plugin, kterou si uživatelé k sobě v dobré víře nainstalovali. Jeden takový případ jsme už v minulosti řešili (a i přes nahlášení CSIRT týmu stále vesele nejspíš běží):
<https://www.server<redacted>.cz/blog/ddos-http-flood/>
 - Bohužel tentokrát jsem nenašel žádné vodítko, kterého se můžu chytit.
 - V příloze přikládám část access logu z dnešního incidentu pro další možnou další analýzu. Jako možného pomocníka při debugu vidím existenci EUI-64 IPv6 adres v access logu, pomocí kterých by mohlo být možné identifikovat přesně konkrétní zařízení v síti.
 - Časové pásmo jak v logu, tak v tomto textu je Praha.
 - Předem děkuji za reakci a přeji hezký den.
- Incoming reports inserted into the ticket system.
- Identification number [CSIRT-MU #2614966] assigned.

Refresher: Incident handling phases



Report Triage

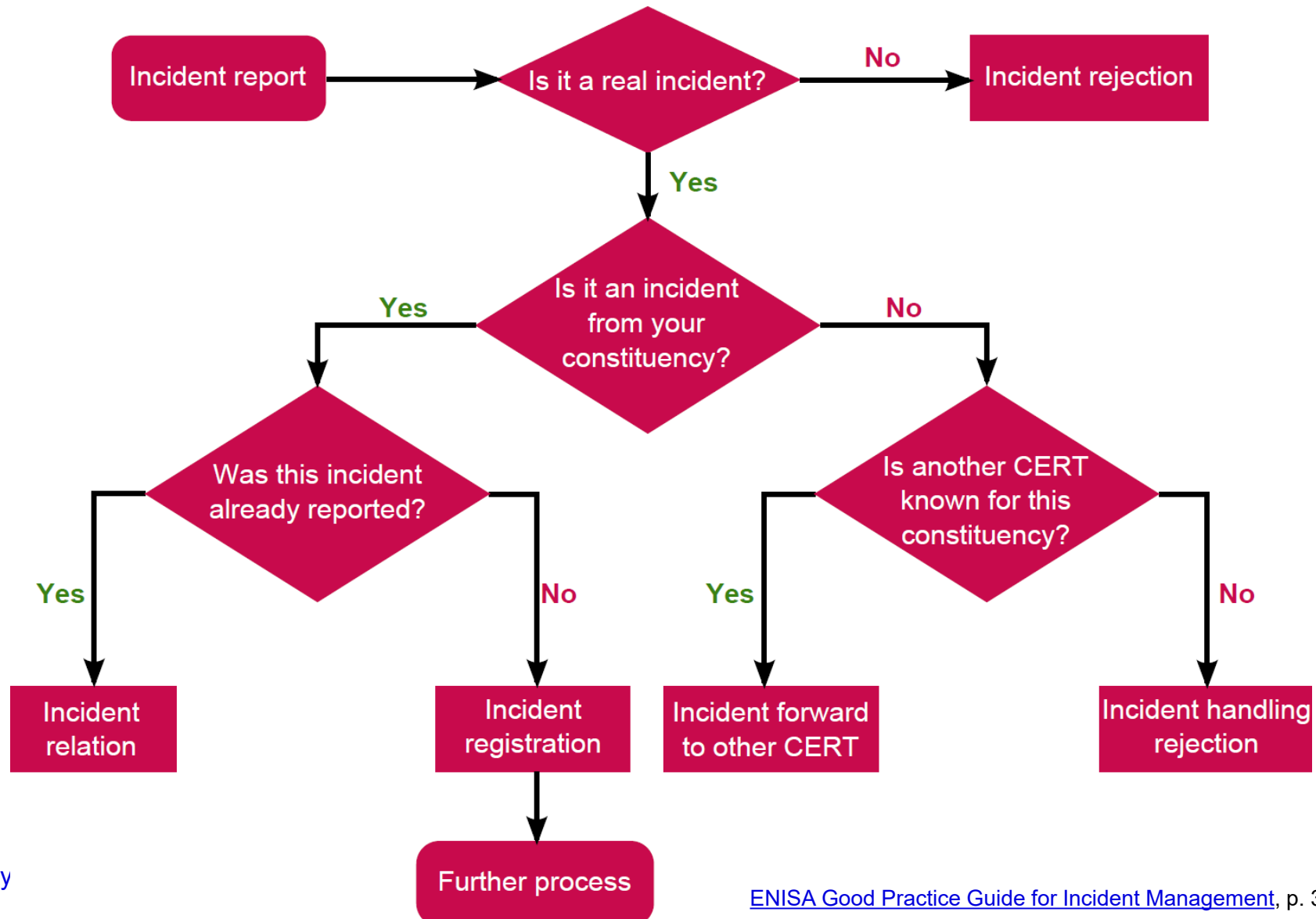
Context for the Whole IH Process



Triage Goals

- Initial assessment of the report
- Incident verification
- Incident classification
- Incident prioritization
- Incident assignment

Report Assessment



Incident Verification

- Is it a security incident?
 - “My PC doesn’t work”, “The website is down”, “I cannot log-in”.
 - Can be an operational issue or a result of a cyber attack.
- Can I confirm the attack/vulnerability using my (monitoring) tools?
 - Does the report contain the required information?
 - Only for easy verifiable ones, e.g., opened VNC to the world.
- Check if you have a mandate to solve the incident
 - Does it fall inside your constituency?
- Check for duplicates
 - Remove duplicate reports or update already opened case with new information.

Incident Classification

- Initial assessment of the incident
 - Often changes later when new evidence is found
 - i.e., [ENISA Reference Security Incident Classification Taxonomy](#)
- You can set different level of support according to the type
 - Or even dismiss incidents you don't consider as high risk, e.g., port scanning

Incident Prioritization

- Initial estimate of the incident impacts
- Based on incident classification

[ENISA Good Practice Guide for Incident Management](#), p. 48:

Priority	Example attacks
Very high	DDoS, phishing site
High	Trojan distribution, unauthorised modification of information
Normal	Spam, copyright issue

- Based on targeted system/customer
 - Does your SLA contain response/recovery time?
 - Does it threaten your critical infrastructure?

Incident Assignment

- Allocate the required number of incident handlers and assign them to the task
- Based on availability
 - Typically, the one who is on duty and saw the report first
 - Consider future availability (shift change, planned vacations, etc.)
- Based on your team specialization
 - Malware specialist takes phishing with attachment
 - Network analyst takes exploited web case

Incoming Report Processing

Incident Report

- “Origin” of all incidents
 - Even your own systems send reports
 - Must contain information required for incident triage
- Comes from various sources in various formats
- Both manually and automatically
- Individual work (activity)
 - Read the initial report and try to answer the triage questions
 - What do you think about the report itself? Does it contain all you need, is it easy to triage?

Report Example 1 – Sony LLC

The following table of IP addresses, dates and times should help you correlate the origin of the abusive activity. The time stamps are approximate from our logs. The actual timing of the events depend on the signature matched. It is very likely to have occurred both before, during and following the times listed.

Approximate Time Range (UTC), IP Address, Reason

*2018-07-30 19:19:00 ~ 2018-07-30 20:19:00 (UTC), 147.251.***.***, Account Takeover Attempts*

It is most likely the attack traffic is directed at one of the following endpoints:

account.sonyentertainmentnetwork.com

auth.api.sonyentertainmentnetwork.com

These endpoints on our network are resolved by Geo DNS, so the IP addresses they resolve to will depend on the originating IP address.

The destination port will be TCP 443.

Please take the necessary measures to correct the malicious activity from the above-listed IP addresses as soon as possible to avoid any further disruptions. If we were to remove any of these IP addresses from the blacklist and subsequent abusive activity is detected, the IP address will be promptly blacklisted again.

Triage Example 1 – Sony LLC

– Checklist approach:

Triage step	Answer
Real	?
Security incident	?
My constituency	?
New report	?
Can I confirm it in my data	?
Incident classification	?
Incident priority	?
Incident assignment	?

Triage Example 1 – Sony LLC

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes
Can I confirm it in my data	Yes
Incident classification	Intrusion Attempts – Login attempts*
Incident priority	Normal – a wi-fi host attacking outside target
Incident assignment	One person, the first one to stumble upon the report

* Will probably result in *Intrusions – System Compromise* as it is more likely an infected host than user intentions. But current data does not allow us to classify it unambiguously.

Report Discussion

- „*It is very likely to have occurred both **before, during, and following the times listed***“
 - No clear timestamp to verify traffic
 - Usually, tens of minutes or even hours off of the real incident timestamp
- Most likely the attack traffic is directed at one of the following endpoints
 - No clear IoC to verify an incident
- Abusive activity (account takeover attempts)
 - No clear IoC to verify an incident

Report Example 2 – Bounty Hunter

Hello, I found a security flaw related to your publicly accessible assets.

--- Affected Instance 1 ---

Finding: WordPress REST API User Enumeration

Severity: Low

Affected Asset: <https://disa.fi.muni.cz/wp-json/wp/v2/users/>

Description:

The REST API exposed user data for all users who had authored a post of a public post type. WordPress 4.7.1 limits this to only post types which have specified that they should be shown within the REST API.

Tags: cve2017, cve, wordpress, wp, edb

Evidence:

- admin*
- d***l*
- m****o*
- M*****o*

This message is shared to support your technical team in maintaining the security of your infrastructure.

Should you need any further information or clarification, please reach out.

Triage Example 2 – Bounty Hunter

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	?
My constituency	?
New report	?
Can I confirm it in my data	?
Incident classification	?
Incident priority	?
Incident assignment	?

Triage Example 2 – Bounty Hunter

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes
Can I confirm it in my data	Yes
Incident classification	Vulnerable – Information disclosure
Incident priority	Normal – web server of our organization affected
Incident assignment	One person, the first one to stumble upon the report

Report Discussion

- Vulnerable endpoint identified precisely
- Easy to verify and reproduce
- Provided evidence
- Vulnerability described

Bounty Hunters Want Rewards

- Report follow-up
 - *„Let me know if you need anything else from my side
I hope this type of hard effort deserve something rewards“*
- We don't have any bug bounty program and cannot pay
 - *„If possible can you please provide me recommendations on linkedin“*
- We do have a responsible disclosure policy with a Hall of fame
 - https://security.muni.cz/en/responsible_disclosure

Report Example 3 – Paramount Pictures

Dear Sir or Madam:

I certify under penalty of perjury that I am authorized to act on behalf of the Paramount Global companies CBS Broadcasting Inc., CBS Studios Inc., Paramount Pictures Corporation, Showtime Networks Inc., Viacom International, Inc., Black Entertainment Television LLC, and other Paramount Global subsidiaries and affiliates (collectively, the “Rights Owners”), the owners of certain exclusive intellectual property rights in the copyrighted work(s) identified in this notice. I have a good faith belief that the information in this notice is accurate.

We have become aware that the below IP addresses have been using your service for distributing video files, which contain infringing video content that is exclusively owned by the Rights Owners. We have a good faith belief that the Rights Owners’ video content that is described in the below report has not been authorized for sharing or distribution by the copyright owner, its agent, or the law. Such copying and use of this material constitutes clear infringement of the Rights Owners’ rights under the Copyright Act and its counterpart laws around the world.

We are requesting your immediate assistance in removing and disabling access to the infringing material from your network. We also ask that you ensure the user and/or IP address owner refrains from future use and sharing of the Rights Owners’ materials and property.

In complying with this notice, you should not destroy any evidence that may be relevant in a lawsuit relating to the infringement alleged; including all associated electronic documents and data relating to the presence of the infringing items on your site, which shall be preserved while disabling public access, irrespective of any document retention or corporate policy to the contrary. Nothing in this letter shall be construed as a waiver or relinquishment of any right, remedy, or claims possessed by the Rights Owners, or any affiliated party, all of which are expressly reserved.

Should you have any questions, please contact me at the information below.

Ben Sodos

Vobile, Inc. Address: 2880 Lakeside Drive, Suite 200

Santa Clara, CA 95054, United States

Email: p2p@copyright-notice.com

Report Example 3 – Paramount Pictures cont.

Evidentiary Information:

- <TimeStamp>2025-08-21T10:37:30Z</TimeStamp>
- <IP_Address>147.251.22.11</IP_Address>
- <Port>60409</Port>
- <Type>BitTorrent</Type>
- <Title>Star Trek: Lower Decks</Title>
- <FileName>Star.Trek.Lower.Decks.S01.1080p.AMZN.WEB-DL.1080p</FileName>
- <FileSize>1929640594</FileSize>
- <Hash Type="SHA1">8166237eaadfca7570489ca93287b9a3be3df9f4</Hash>

Triage Example 3 – Paramount Pictures

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	?
My constituency	?
New report	?
Can I confirm it in my data	?
Incident classification	?
Incident priority	?
Incident assignment	?

Triage Example 3 – Paramount Pictures

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes
Can I confirm it in my data	Partially – we can see torrent traffic, not the content
Incident classification	Fraud – Copyright
Incident priority	Normal – a wi-fi host with torrent client
Incident assignment	One person, the first one to stumble upon the report

Report Discussion

- Clear identification of source and time
 - Can easily verify traffic monitoring records
- Clear identification of abuse

Report Example 4 – CSIRT.CZ Sinkhole Report

E-mail text

Dear colleagues,

On behalf of the National Security Team CSIRT.CZ and in connection with the project Prediction and Protection against Cybernetic Incidents (PROKI, ID: VI20152020026) implemented under the Security Research Program of the Czech Republic for the years 2015–2020, we are sending you a comprehensive report on the IP addresses from your network that have been evaluated as potentially harmful.

Please find attached the list of activities from your IP ranges that have been recorded in various security information sources over the past 7 days in the format:

time_detected, ip, class, type, time_delivered, country_code, asn, description, malware, feed_name, feed_url, raw

We would like to request that you kindly investigate the findings and arrange the necessary remedy with the operators of the mentioned machines.

Attached CSV

```
time_detected,ip,class,type,time_delivered,country_code,asn,description,malware,feed_name,feed_url,raw
2025-07-09T16:48:39+00:00,217.69.***.***,malicious-code,infected-system,2025-07-10T15:39:07+00:00,CZ,198500,,android.badbox2,Sinkhole-Events-HTTP IPv4,,
„2025-07-09 16:48:39“, tcp, 217.69.***.***, 54060, 198500, CZ,
JIHOMORAVSKY KRAJ, HORNI HERSPICE, critical, 178.162.203.202, 80,
28753, DE, HESSEN, FRANKFURT AM MAIN, 518210, Communications,
Service Provider, and Hosting Service, android.badbox2, 1752079719,
POST /stat/ HTTP/1.0, t.ontoot.com, Dalvik/2.1.0(Linux; U; Android 7.1.1;
SMART_W10X_EEA Build/SMART_W10X_EEA_01.01.05)“
```

Report Example 4 – CSIRT.CZ Sinkhole Report

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	?
My constituency	?
New report	?
Can I confirm it in my data	?
Incident classification	?
Incident priority	?
Incident assignment	?

Report Example 4 – CSIRT.CZ Sinkhole Report

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes and No
New report	Yes
Can I confirm it	Yes
Incident classification	Malicious Code – Infected System
Incident priority	Very high – commercial client
Incident assignment	One person for coordination with external partner

Report Discussion

- Clear identification of source and time
- Delivery by e-mail as a text file in ZIP archive attachment is cumbersome
 - PROKI also offers REST API, but you need to pull the data periodically
- Nested CSVs of the PROKI platform and the original source make machine parsing almost impossible
- Clear identification of the problem
 - Included botnet C&C IP address and IoC URL

Report Example 5 – EGI Report

Sudo vulnerabilities

HIGH risk privilege escalation vulnerabilities found in sudo, CVE-2025-32462 and CVE-2025-32463.

IDs AND CVSS SCORE

EGI SVG ID: EGI-SVG-2025-10

CVE ID: CVE-2025-32462, CVE-2025-32463

CVSS Score: 7.8 [R 4] (N.B. 9.3 for Ubuntu)

HIGH risk privilege escalation vulnerabilities concerning sudo, CVE-2025-32462 and CVE-2025-32463.

AFFECTED SOFTWARE AND VERSIONS

CVE-2025-32462:

- Affects sudo versions 1.8.8 to 1.9.17 inclusive. [R 11]*
- RHEL is affected, with fixes available. [R 3]*
- Debian is affected, with fixes available. [R 5]*
- Ubuntu is also affected, with fixes available. [R 7]*

CVE-2025-32463:

- Affects sudo versions 1.9.14 to 1.9.17 inclusive. [R 12]*
- RHEL is not affected unless non-standard sudo configuration is in effect. [R 4]*
- Debian: Only the unstable (trixie) release is affected, in which case the risk is CRITICAL, and sudo must be upgraded immediately. [R 6]*
- Ubuntu: 24.04 (noble) and later are affected and the risk is CRITICAL. Packages must be upgraded immediately. [R 8]*

Report Example 5 – EGI Report

ACTIONS REQUIRED/RECOMMENDED

Sites are recommended to update relevant components as soon as possible using information in the references below.

Sites should be aware that if a public exploit is released which allows easy root access in the EGI infrastructure this vulnerability is likely to be elevated to 'Critical' and sites will then be required to patch or have mitigation in place within 7 days or risk suspension.

MITIGATION

Mitigations for CVE-2025-32462 can be found on the Red Hat CVE page. [R 3]

STATUS OF THIS ADVISORY

TLP:AMBER information - Limited distribution

This advisory will be made public on or after 2025-07-30 at:

<https://advisories.egi.eu/Advisory-EGI-SVG-2025-10>

<https://advisories.egi.eu/Advisory-SVG-CVE-2025-32462>

<https://advisories.egi.eu/Advisory-SVG-CVE-2025-32463>

— The report was sent on 2nd July 2025, now it is public.

Report Example 5 – EGI Report

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	?
My constituency	?
New report	?
Can I confirm it in my data	?
Incident classification	?
Incident priority	?
Incident assignment	?

Report Example 5 – EGI Report

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	No
My constituency	Yes
New report	Yes
Can I confirm it	x
Incident classification	x (Other – <i>Uncategorised if system needs the field filled</i>)
Incident priority	x (High, but not for CSIRT, admins need to react)
Incident assignment	x

Report Discussion

- Markdown format is not very suitable for e-mails.
- Not every incoming report is an incident.

Report Templates

- Make it easier to report incident
 - Define what information you want from the reporter
 - Prepare a form for convenience
- Speed-up the work when you report an incident
 - To a third-party
 - To your constituents
- Human vs. machine readable form
 - Avoid wall of useless text
 - The important parts (IoC, timestamp, source IP) should be structured and separated from the explaining text

Report Templates – Example for Humans

<https://it.muni.cz/en/services/security-incidents-reporting>

STEP 1: Choose a method to report the incident

You can report an incident in two ways:

1. Send an email to csirt@muni.cz.
2. Fill out the form ([here](#)).

In urgent cases, you can call +420 549 494 242 on weekdays (9:00 AM–5:00 PM) to directly reach the Cybersecurity incident response team.

STEP 2: Provide the necessary information

Whichever form of reporting you choose, please always complete:

1. **First name, last name, UČO** -> Cybersecurity experts dealing with the incident must verify your identity.
2. **Describe the problem in detail** -> describe the problem as precisely as possible ([example of possible signs of a PC attack](#)), and we will ask you if necessary.

Reporting incidents via personal email without providing a UČO may delay the resolution process, so please use university email.

STEP 3: Submitting of evidence

For the submitting of evidence, follow these guidelines:

1. **Email communication**(e.g., phishing or malware) -> forward the email or attach the text with links, including attachments and headers - instructions for exporting headers can be found [here](#).
2. **Other incidents**(e.g. ransomware on a device) -> forward relevant supporting documentation, including images (e.g., screenshots) with the email text.

Screenshots can also be helpful for incidents within email communication but always make it a priority to forward the email text with headers.

Report Templates – Example for Humans

 **Report a cybersecurity incident**

Name (required)

E-mail (required)

Message (required)

Files with incident information

 **UPLOAD**

☐ I agree with [Personal data processing and protection rules](#) (required)

Activity – Phishing Triage

Phishing Activity – Background

- CSIRT-MU has received lots of reports of phishing attacks in one day.
- Sample reports from users are available in IS – [Activity-Phishing.pdf](#)
- For simplicity, assume you have received 50 reports of each type.
- You are the only incident handler currently on duty (work on your own).
- Please process the reports.

Phishing Activity – Tasks

Carry on incident triage of each report. You can use the checklist from this slide:

- Is it a real incident?
- Is it a security incident?
- Does it fall into my constituency?
- Is it a new incident?
- Can I confirm the incident?
- What is the incident classification?
- What is the incident priority?
- Who will resolve the incident?

Phishing Triage – Report 1

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes – for the first one
Can I confirm it	Yes
Incident classification	Fraud – Phishing
Incident priority	Very high – spear-phishing targeting lots of users
Incident assignment	One – there is no one else in the office ☹ Ideally two handlers – one for responding to all users, one for incident coordination and advisory

What You See in Ticket System

č. 	Předmět  Žadatel 	Stav  Vytvořeno 	Fronta  Poslední kontakt 
778147	Fwd: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778149	PHISHING Fwd: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778151	FW: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778153	FW: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778155	FW: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778156	[UVT MU #770554] Fw: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778157	FW: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778158	FW: [UVT MU #770554] Fw: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778160	Fwd: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778167	Fwd: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778171	Fwd: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety
778176	FW: Je vyžadována akce: Čtvrtek 5. listopadu 2020 [redacted]@muni.cz>	vyřešený před 4 lety	General před 4 lety

Phishing Triage – Report 2

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes – for the first one
Can I confirm it	Yes
Incident classification	Malicious Code – Malware Distribution
Incident priority	Very high – spear-phishing targeting lots of users
Incident assignment	One – there is no one else in the office ☹ Ideally three handlers – one for responding to all users, one for incident coordination and advisory, one for malware and IoC analysis

Phishing Triage – Report 3

– Checklist approach:

Triage step	Answer
Real	Yes
Security incident	Yes
My constituency	Yes
New report	Yes – for the first one
Can I confirm it	Yes
Incident classification	Fraud – Phishing
Incident priority	Normal – generic phishing bordering spam
Incident assignment	One, the first to stumble upon the report

Phishing Triage Discussion

- Which of the phishing campaigns you view as the most dangerous and why?
 - Phishing on IS vs. malware vs. donation?
 - What if the phishing was not on IS of university, but on internet banking?
 - What can we do with the malware?

Homework 1

Homework 1

- **Goal:** categorization of five incident reports according to the ENISA taxonomy
- **Assignment:** see Study materials in [Homework1-Incident_categories.pdf](#)
- **Submission:** ROPOT (Odpovědník) **Homework 1 in IS MU**
- **Deadline:** **October 14, 2026, 10:00**
- **Contact person:** Jan Vykopal (vykopal@fi.muni.cz)

Homework 1 – Grading – 0–5 points

- There might be more correct answers for each report/alert.
- We will accept your answer if you provide relevant justification.
- Justification can be written in Czech, Slovak, or English.
- No or wrong answer = 0 points. No justification = 0 points.
- No information about AI use = 0 points.
- Points = no. of correct answers with justification.

Next week

- You will work with a document in a class activity.
- Bring your own laptop if you can. You will appreciate a bigger display than on your phone.

Questions, answers, and feedback in Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Go to: <https://claper.fi.muni.cz/e/pv210>
- **Please provide us with feedback:**
How can today's class be improved?

